

Table of Contents

Cisco Secure Workload — NIST SP 800-207 Zero Trust Architecture

Technical Runbook | Federal Agencies & Enterprise Accounts

Version: 1.0 | **Standard:** NIST SP 800-207 (Zero Trust Architecture — Seven Tenets) |

Environment: Hybrid

Reader's Guide

Who this is for. Any organization adopting Zero Trust Architecture — federal agencies executing on EO 14028, federal contractors, enterprises with a strategic ZT initiative — plus the security architects working with them.

Questions this runbook helps you answer:

- *For each of the seven tenets, where do I have a real working implementation today vs. a slide that says "we do this"?*
- *Tenet 1 says "all data sources and computing services are resources" — what's my live inventory of those resources, and how current is it?*
- *Tenet 2 (all communication is secured regardless of network location) — can I prove that every workload-to-workload conversation is policy-allowed, not just network-reachable?*
- *Tenet 5 says the enterprise monitors and measures "integrity and security posture of all assets" — what does that look like as a daily artifact, not an annual audit?*
- *In my deployment model (agent-based, enclave-based, resource portal), which CSW components live where in the architecture?*
- *When my architect asks "where's the Policy Enforcement Point?", what's my answer?*

What you'll need. A current zero-trust strategy document or charter, your existing architecture diagram (even if aspirational), your identity provider integration map, and a sense of which deployment model best fits your environment.

Where to start. Section 1 to align on terminology; section 2 to walk tenet-by-tenet; section 3 for the logical-component mapping (this is where most architectural discussions live); section 4 if you're committing to a deployment model; section 5 to see how CSW fits Cisco's broader ZT portfolio.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥2 weeks; export clusters; app-	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
		owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Workload-side evidence for ZTA Tenets 2/3/5/6
- PEP placement on workload with policy export for assessors
- PIP-style telemetry from process + flow graph

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

NIST SP 800-207 defines Zero Trust Architecture (ZTA) through seven foundational tenets. Unlike maturity models (e.g., CISA ZTMM), 800-207 focuses on architectural requirements and logical components — the Policy Engine (PE), Policy Administrator (PA), and Policy Enforcement Point (PEP).

CSW's role in 800-207 architecture:

- **Policy Enforcement Point (PEP):** CSW micro-segmentation enforces workload-level access decisions
 - **Policy Information Point:** CSW telemetry (vulnerability, process, flow) feeds the policy engine
 - **Continuous Diagnostics:** CSW provides the asset posture monitoring required by 800-207's CDM integration
-

2. Tenet-by-Tenet Implementation Guide

Tenet 1 — All Data Sources and Computing Services Are Resources

Goal: Every asset — on-prem, cloud, IoT, SaaS — is treated as a managed resource, regardless of ownership or location.

CSW Implementation:

Step 1: Deploy software sensors on all on-prem workloads

- Linux: rpm/dpkg install + systemctl enable csw-agent
- Windows: MSI install + service verification

Step 2: Connect cloud accounts (agentless discovery)

CSW UI → Platform → External Orchestrators

- AWS: IAM Role with EC2/VPC read permissions
- Azure: Service Principal with Reader role
- GCP: Service Account with Compute Viewer role

Step 3: Label every workload as a classified resource

Mandatory labels:

```
env:           production | staging | dev
data:          phi | pii | pci | sensitive | public
compliance:    nist-800-207 | hipaa | pci | none
app:           [application name]
owner:         [team name]
```

Step 4: Validate CSW coverage and label completeness

CSW UI → Inventory

→ Filter: label missing → Identify unlabeled workloads

→ Target: 100% label coverage for in-scope CSW-covered workloads
before ADM run

Evidence: Inventory export (CSV), cloud connector discovery report

Tenet 2 — All Communication Is Secured Regardless of Network Location

Goal: No implicit trust based on network position. All traffic — internal and external — must be authenticated and encrypted.

CSW Implementation:

Step 1: Identify unencrypted communications via ADM

CSW UI → Investigate → Flow Search

Filter: Protocol = HTTP (80), FTP (21), Telnet (23), LDAP (389)

Scope: All monitored workloads

→ Export: Unencrypted flow report (baseline)

Step 2: Create blocking policies for non-compliant protocols

CSW UI → Defend → Segmentation → New Workspace

Name: ZTA-Encryption-Enforcement

DENY policies:

```
DENY: Any → Sensitive-Scope (port 80)    # HTTP
DENY: Any → Sensitive-Scope (port 21)    # FTP
DENY: Any → Sensitive-Scope (port 23)    # Telnet
DENY: Any → Sensitive-Scope (port 389)   # Plain LDAP
DENY: Sensitive-Scope → Any (port 80)    # HTTP egress
```

Step 3: Run in Simulation mode first

→ Validate no legitimate apps broken by encryption enforcement

→ Work with app owners to remediate unencrypted dependencies

→ Enforce after 2-week simulation validation

Step 4: Quarterly re-scan

→ Re-run Flow Search for unencrypted protocols

→ Any new violations: immediate alert + policy update

Evidence: Unencrypted flow report (before/after), policy enforcement log, quarterly protocol compliance report

Tenet 3 — Access to Individual Resources Is Granted Per-Session

Goal: Access must be scoped to specific individual resources, evaluated per connection. No broad network segment access.

CSW Implementation:

Step 1: ADM-based individual resource policy

CSW UI → Investigate → ADM

→ Run for minimum 4 weeks on all scopes

→ Export ADM clusters = individual resource access map

Step 2: Build workload-level allowlist (not subnet-level)

For each workload in sensitive scope:

ALLOW: [Source Workload A] → [Dest Workload B] (port X)

ALLOW: [Source Workload C] → [Dest Workload B] (port Y)

DENY: All other → [Dest Workload B]

Key principle: policies reference workload identity (hostname/label), NOT IP ranges or subnets

Step 3: Default-deny for all sensitive scopes

→ Every sensitive workload starts with DENY ALL inbound

→ Only explicitly documented flows are permitted

→ No "allow same subnet" rules – violates Tenet 3

Step 4: Per-connection audit trail

CSW logs every connection: source, destination, process, user, timestamp, bytes, and policy decision (allow/deny)

→ Contributes to per-access records for network connections CSW observes;

validate required fields against your logging standard

Evidence: Per-connection flow log export, policy workspace (allowlist rules), policy denial log

Tenet 4 — Access Is Determined by Dynamic Policy

Goal: Policy must incorporate observable state — device posture, user behavior, environmental conditions. Static rules are insufficient.

CSW Implementation:

4a. Label-Driven Dynamic Scoping

When a workload label changes → scope membership updates → policy applies automatically

Example:

- Workload X gains label: data=phi
- Workload X auto-joins PHI-Zone scope
- PHI-Zone policies (default-deny, encrypted-only) apply immediately
- No manual policy rule change required

4b. Vulnerability-Informed Compensating Controls

CSW vulnerability alert → SOAR → CSW API policy update

Workflow:

Trigger: New Critical CVE (CVSS 9.0+) detected on Workload Y

SOAR Action:

POST /openapi/v1/policies

Body: {

```
"name": "vuln-compensating-Workload-Y",  
"priority": "HIGH",  
"action": "ALLOW",  
"src": "Admin-Jump-Host",  
"dst": "Workload-Y",  
"port": "22"
```

}

+ DENY all other inbound to Workload-Y

Duration: Until patch applied + vulnerability cleared

4c. SOAR-Mediated Dynamic Isolation

CSW anomaly alert → SOAR → CSW API → Workload isolation

Example SOAR playbook (Splunk SOAR / Palo Alto XSOAR):

Trigger: CSW high-severity anomaly on Workload Z

Step 1: Query CSW API for workload identity

Step 2: Create isolation policy via CSW API

Step 3: Notify SOC analyst with context

Step 4: Await analyst approval to restore normal policy

Evidence: API audit log, SOAR-to-CSW integration log, label-change-to-policy-update trace

Tenet 5 — Enterprise Monitors and Measures Integrity and Security Posture of All Assets

Goal: Continuous, automated asset health monitoring. No assumed-healthy assets. Posture data feeds access decisions.

CSW Implementation:

Vulnerability Monitoring:

- CSW UI → Investigate → Vulnerability
- Continuous scan (no scheduling required)
- Alert thresholds:
 - CVSS 9.0+: Alert SIEM immediately
 - CVSS 7.0–8.9: Alert within 4 hours
 - CVSS 4.0–6.9: Daily digest
- Export: Weekly vulnerability report per scope

Process Integrity Monitoring:

- CSW UI → Alerts → Process Anomaly
- Enable: New process not in ADM baseline
- Enable: Process hash change (modified binary)
- Enable: Unexpected listening port (new service)
- Alert: SIEM + email + Webex

Configuration Drift Detection:

- CSW compares current state to ADM baseline continuously
- New flow not in baseline: Alert
- New process not in baseline: Alert
- New port not in baseline: Alert
- Quarterly ADM re-run: Validate and update baseline

Evidence: Vulnerability trend report (weekly), process anomaly alert log, configuration drift report

Tenet 6 — Authentication and Authorization Are Dynamic and Strictly Enforced

Goal: Every access request must be authenticated and authorized. No cached, assumed, or implicit authorizations.

CSW Role (Network Enforcement Layer):

CSW enforces the network path to authentication systems:

DENY policies for unauthenticated paths:

- DENY: Any → Sensitive-Scope (port 389) # Block plain LDAP
- DENY: Any → Sensitive-Scope (port 5985) # Block WinRM HTTP
- DENY: Any → DB-Servers (unauthenticated ports)

ALLOW policies for authenticated paths only:

- ALLOW: App-Servers → LDAP-Server (port 636) # LDAPS only
- ALLOW: Workstations → KDC (port 88) # Kerberos
- ALLOW: Jump-Host → Sensitive-Scope (port 22) # SSH only

Complementary Controls Required for Full Tenet 6: | Capability | CSW | Complementary

Tool | ---|---|---| | Network path to auth systems |  CSW enforces | — | | Identity Provider (IdP) authentication |  Not CSW | Okta, Azure AD, Cisco ISE | | MFA enforcement |  Not CSW |

Duo Security, Azure MFA || Continuous session re-evaluation | ❌ Not CSW | Cisco Secure Access (ZTNA) || Device certificate validation | ❌ Not CSW | Cisco ISE, Intune |

Evidence: LDAPS enforcement log, unauthenticated access alert log, auth path policy workspace

Tenet 7 — Enterprise Collects Information and Uses It to Improve Security Posture

Goal: Telemetry collection is not just for alerting — it must feed a continuous improvement loop that evolves the security posture over time.

CSW Implementation:

7a. SIEM Integration

CSW UI → Platform → External Systems

- Kafka: Real-time event streaming (recommended)
- Syslog: UDP/TCP syslog to SIEM
- Data types: Flows, alerts, vulnerabilities, process events

SIEM use cases from CSW data:

- Threat hunting: Cross-correlate CSW flows with EDR alerts
- Compliance reporting: Automated evidence package generation
- Trend analysis: Vulnerability posture over time
- Anomaly correlation: CSW behavioral + identity + endpoint

7b. ADM Continuous Improvement Loop

Quarterly cycle:

- Month 1: Re-run ADM on all scopes
- Month 2: Delta analysis – new flows vs. previous ADM
 - New flows: Review and approve or block
 - Removed flows: Clean up stale policy rules
 - New attack surface: Tighten policy
- Month 3: Update policy workspace to reflect ADM delta
 - Retire stale rules
 - Add newly documented flows
 - Document changes for audit trail

7c. Compliance Reporting Cadence

Monthly: Scope membership snapshot + policy change log

Quarterly: Vulnerability trend report + ADM delta + encryption compliance

Annual: Full ZTA posture assessment + evidence package for auditors

Evidence: SIEM integration config, ADM delta report (quarterly), compliance posture report (annual)

3. NIST 800-207 Logical Components — CSW Mapping

NIST 800-207 Component	CSW Implementation
Policy Engine (PE)	CSW policy engine — evaluates flows against allowlist rules
Policy Administrator (PA)	CSW policy workspace — authors and deploys policy decisions
Policy Enforcement Point (PEP)	CSW software sensor — enforces allow/deny per connection
CDM System (asset posture)	CSW vulnerability + process telemetry → SIEM feed
SIEM	CSW → Kafka/Syslog → enterprise SIEM
ID Management	CSW enforces auth path; IdP provides identity (complementary)
PKI	CSW enforces encrypted path; PKI manages certificates (complementary)

4. Deployment Models — CSW Role

Agent-Based ZTA (Primary CSW Model)

CSW software sensor on each workload = PEP at the workload level. Full visibility, process context, and enforcement. Best coverage of all seven tenets.

Enclave-Based ZTA

CSW eliminates implicit intra-enclave trust. ADM validates every intra-enclave flow. Micro-segmentation enforces workload-level policy within the enclave. Prevents lateral movement that enclave-gateway-only models miss.

Resource Portal-Based ZTA

CSW protects backend resources behind the portal. Enforces that ONLY the portal IP/workload can reach backend resources. Detects any direct-access bypass of the portal path — a critical security gap in portal-only deployments.

5. Integration with Cisco Zero Trust Portfolio

For full NIST 800-207 coverage, CSW operates alongside:

Cisco Product	800-207 Role	Tenets Covered
Cisco Secure Workload (CSW)	Workload PEP, posture monitoring, east-west enforcement	1, 2, 3, 4, 5, 7
Cisco Secure Access (SSE/ZTNA)	User-to-application PEP, identity-aware access	3, 6
Cisco ISE	Device authentication, NAC, certificate management	6
Cisco XDR	Cross-domain telemetry correlation, threat detection	5, 7
Cisco Multicloud Defense	North-south enforcement, cloud gateway	2, 3

6. Evidence Package for 800-207 Assessment

Assessment Area	CSW Evidence	Format	Frequency
Resource inventory completeness	Inventory export + ADM resource map	CSV	Monthly
Communication security	Unencrypted flow report (before/after)	CSV	Quarterly
Per-resource access control	Policy workspace + flow log	Export	Continuous
Dynamic policy capability	API audit log + label-change trace	Log	Per change
Asset posture monitoring	Vulnerability trend + process anomaly log	CSV/PDF	Weekly/Real-time
Authentication enforcement	LDAPS policy log + unauthenticated access alerts	Log	Continuous
Continuous improvement	ADM delta report + SIEM feed config	PDF/Config	Quarterly

Related Frameworks

- [NIST SP 800-207A — PDP/PEP/PA/PIP](#) — the logical-component view that operationalises the seven tenets.
 - [CISA Zero Trust Maturity Model v2.0](#) — the maturity-tier view that plots progress against the same architecture.
 - [NIST SP 800-53 Rev 5](#) — the federal control catalogue most often paired with 800-207 in agency programmes.
 - [DORA \(EU 2022/2554\)](#) — DORA's segmentation and continuous-monitoring expectations sit on the same ZTA foundation.
 - [NIS2 \(EU 2022/2555\)](#) — for EU essential/important entities, ZTA principles directly inform Article 21(2)(a), (b), (j).
-

Customer-facing guidance. Tailor examples and scope notes to your environment before formal audit submission. For full NIST 800-207 Zero Trust Architecture coverage, pair CSW with complementary identity, access, and detection controls (for example: Cisco Secure Access, Cisco ISE, and Cisco XDR).